EPSI · WORKSHOP 2026 · MASTER 2

PROJECT RESILIENCE-ALPHA

Xijin Pink

Une plateforme de dons fictive face à un incident de sécurité — détection, reprise automatique, gouvernance.

Support de présentation · 10 minutes

Julien Demogue
Services et API

Louis Marec
IA et données

Eric Girard
Infrastructure

Noé Filippi
Frontend

Sterenn
Frontend

Groupe G2 · Octobre 2026

Ce que nous allons voir

01 **Contexte et objectifs**
Pourquoi ce démonstrateur, et ce qu'on entend par « reprise »

02 **Architecture de la plateforme**
Les briques et leur rôle

03 **Le scénario démontré**
L'incident mis en avant et sa preuve de reprise

04 **Intelligence artificielle**
Détection d'anomalies et assistant opérateur

05 **Reprise automatique**
Zero-touch recovery

06 **Sécurité en profondeur**
WAF, paiement signé, SOC

07 **Authentification faciale**
Consigne additionnelle et voyant connecté

08 **Résultats des essais**
Ce que montrent les chiffres

09 **Gouvernance**
EBIOS RM et PCA/PRA

10 **NIS2 / DORA**
Limites et recommandations

Un incident de sécurité, sans intervention humaine

01

- **Xijin Pink** est un prestataire de paiement fictif qui collecte des dons pour Octobre Rose, construit en une semaine de workshop.
- Trois questions guident le projet : quand une attaque frappe, **la voit-on**, **la comprend-on**, et **le service redevient-il utilisable** ?
- Notre définition de la reprise : l'API répond, un **nouveau don atteint le statut « paid »**, et les données restent cohérentes.
- Un conteneur qui redémarre **ne prouve rien** — c'est le point de départ de toutes nos décisions techniques.

Toute la plateforme, démarrée en une commande

02

Donateur / Jury
navigateur, hotspot RESILIENCE-G2

→

WAF Nginx
seule porte d'entrée exposée

→

Frontend React + Tailwind
site de dons

→

Auth · Paiement · PSP simulé
3 services Node.js + MariaDB

- Tout tourne en **Docker Compose** sur le PC Hôte, réseau interne cloisonné, démarrage en une commande (`start.sh`).
- **Observabilité** : Prometheus (métriques), Loki (journaux), Grafana (supervision & SOC).
- **IA** : détecteur d'anomalies par apprentissage + assistant RAG local (Ollama).
- Consigne additionnelle : authentification faciale reliée à un **voyant ESP8266**.

Le déni de service sur le paiement, mis en avant

03

- **5 familles d'attaques** outillées et reproductibles : saturation, bourrage d'identifiants, aspiration, injection, exfiltration.
- Scripts Python lancés depuis le **PC Attaquant**, trafic normal joué en parallèle pour rester réaliste.
- Pour la démo : un **flood** sur le paiement, pendant 60 secondes, avec montée progressive.

Preuve de reprise retenue

Latence et erreurs grimpent pendant l'attaque, puis un **nouveau don fictif aboutit** et atteint le statut payé — l'effet métier se voit, et la reprise aussi.

Détecter, expliquer — jamais décider seule

04

Détecteur d'anomalies

17 indicateurs par fenêtre de 10 s (débit, erreurs, latence, IP…). ACP + Isolation Forest. **Seuil appris automatiquement**, jamais codé en dur.

Assistant opérateur (RAG)

Ollama local, modèle 3B : explique une alerte à partir des runbooks. **Lecture seule**, aucun accès système, ne pilote jamais la remédiation.

10–15 s
délai de détection d'une attaque franche

≈ 0,95
AUROC du score d'anomalie

5 / 5
catégories d'attaque détectées sur données réelles

100 %
local — rien ne sort du laboratoire

Zero-touch recovery

05

- **1ère ligne :** le WAF limite le débit par adresse et répond 429 avant d'atteindre `payment-api`.
- **Docker :** tous les services en `restart: unless-stopped`, contrôle de santé sur MariaDB.
- **Données :** transactions persistées sur volume, webhook de paiement idempotent — rejouer une confirmation ne casse rien.
- **Clone neuf :** modèle du détecteur et index de l'assistant se reconstruisent seuls au premier démarrage.
- `scripts/verify.sh` contrôle **11 points de santé** de bout en bout, y compris après un clone neuf.

Chaque couche protège la suivante

06

- **Réseau :** réseau Docker interne cloisonné — seuls le WAF (8080) et Grafana (3000) sont exposés sur le hotspot.
- **Entrée :** WAF Nginx — limitation de débit, blocage SQLi/XSS/traversée, en-têtes durcis, version masquée.
- **Paiement :** webhook signé en **HMAC-SHA256**, comparé en temps constant ; aucune donnée de carte envoyée au serveur.
- **Secrets :** générés au premier démarrage, jamais commités dans le dépôt.
- **SOC / SIEM :** journaux JSON corrélés par `request_id`, tableau Grafana dédié.

Authentification faciale et voyant connecté

07

- Trois facteurs dans l'ordre : **identifiant → visage → mot de passe**.
- Vérification 1:1 par OpenCV (YuNet + SFace), comparée au seul gabarit de l'identifiant saisi.
- Blocage progressif après échec : **5, puis 10, puis 20 minutes**.
- Un **ESP8266** sur le hotspot affiche l'état sur une LED verte / rouge.

Point d'attention RGPD

Les gabarits faciaux sont des données biométriques sensibles (art. 9). Aucune photo n'est stockée — seulement un gabarit, supprimé avec l'habilitation. Pas de détection du vivant : écart assumé et documenté.

Ce que montrent les essais

08

5 / 5
catégories d'attaque détectées, alerte en 10–15 s

4 888
réponses 429 renvoyées par le WAF pendant le flood

42
tests unitaires passants sur l'ensemble du dépôt

11 / 11
points de santé vérifiés, même depuis un clone neuf

≈ 0,93
exactitude du classifieur de catégorie d'attaque

0,74 vs 0,10
similarité faciale : même personne vs personnes différentes

Relier la technique au risque métier

09

EBIOS RM

4 valeurs métier, 6 événements redoutés notés en gravité (1 à 4). Risques résiduels les plus lourds assumés en démonstrateur : **transactions faussées** et **prise de contrôle du back-office**.

PCA / PRA

RTO visé d'**une minute** pour la plupart des services, RPO = 0 grâce à la persistance des transactions.

- Couvert automatiquement : arrêt d'un conteneur, saturation par quelques adresses, redémarrage complet de l'hôte.
- **Non couvert :** perte de l'hôte (pas de second site), perte du volume de la base, compromission avérée.
- Ces cas exigent une **investigation humaine** avant toute remise en service — assumé et documenté.

Ce qu'un prototype de 4 jours peut montrer — et ses limites

10

- Xijin Pink est un **établissement de paiement** fictif : DORA s'applique, NIS2 reste le cadre général.
- **Montré :** cartographie des risques, détection, alertes horodatées, procédures de réponse.
- **Pas montré :** notification réglementaire réelle, tests d'intrusion indépendants (TLPT), validation par la direction.

Nos recommandations prioritaires

Mesurer le taux de fausses alertes avant d'automatiser la remédiation · sauvegarder la base · relancer le webhook en cas d'échec · chiffrer les secrets (Vault/SOPS).

Merci.

Xijin Pink — une démonstration de cyber-résilience, du premier flood à la reprise vérifiée.

Questions ?